

Fundamentals of Information Systems Security

Chapter 3 Quiz Answer Key

Instructor: Guuleed Maxamuud Aw Abdi

Section A: Multiple Choice (40 points)

1. **B** — $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$
2. **C** — Vulnerability
3. **B** — Risk Register
4. **B** — Single Loss Expectancy
5. **B** — $\text{ALE} = \text{SLE} \times \text{ARO}$
6. **B** — Qualitative risk assessment
7. **A** — The time between vulnerability announcement and patch application
8. **A** — No patch exists yet
9. **D** — Financial controls
10. **B** — Vulnerability window

Section B: True/False (20 points)

1. **False** — Risk management is a continuous cycle
2. **True** — Qualitative is faster but more subjective
3. **True** — NVD enhances CVE data
4. **False** — Do not spend more to protect an asset than it is worth
5. **False** — A threat is something bad that might happen
6. **True** — Brute-force tries every combination
7. **True** — Spear phishing is highly targeted
8. **False** — SQL injection is a technical attack, not social engineering
9. **True** — Residual risk remains after controls
10. **True** — The three main threat types are correct

Section C: Short Answer (40 points)

1. Risk, Threat, and Vulnerability (10 points)

- **Vulnerability:** A weakness in a system (e.g., unpatched web server, open network port)
- **Threat:** Any action that can exploit a vulnerability (e.g., hacker, malware)
- **Risk:** The probability that a threat will exploit a vulnerability and the resulting impact
- **Example:** An unpatched server (vulnerability) could be exploited by a hacker (threat) leading to a data breach (risk)

2. Quantitative Risk Assessment (10 points)

- **Asset Value (AV):** Total value of an asset
- **Exposure Factor (EF):** Percentage of asset value lost in a single incident
- **SLE (Single Loss Expectancy):** $SLE = AV \times EF$
- **ARO (Annual Rate of Occurrence):** How many times the threat occurs per year
- **ALE (Annualized Loss Expectancy):** $ALE = SLE \times ARO$

3. Five Steps of Risk Management (10 points)

- (a) Identify Risks
- (b) Assess and Prioritize Risks
- (c) Plan Risk Response
- (d) Implement Risk Response
- (e) Monitor and Control Risk Response

4. Four Risk Responses (10 points)

- **Reduce/Mitigate:** Implement controls to lower probability or impact (e.g., antivirus)
- **Transfer/Assign:** Shift risk to a third party (e.g., cyber insurance)
- **Accept:** Acknowledge and do nothing (cost of mitigation > potential loss)
- **Avoid:** Eliminate risk by discontinuing activity (e.g., not launching product in high-risk country)